CSA6303- Threat Intelligence and Network Security

AT1: Application-Based Questions

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats |Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan **Total: 50**

Student Name :S.TANISHA **Register number:192465008**

Code of Conduct:

I _S.TANISHA(192465008)_ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:S.TANISHA

AT1: Application-Based Questions

Q1.CIA Triad — Scenario Identification (5 marks)
An e-commerce site stays fully online during an incident, but customers notice product prices have been silently changed by an attacker who gained database write access. No downtime occurred. Which CIA Triad principle(s) are violated? Justify your answer

Q2. Risk Quantification — Annualized Loss Expectancy (10 marks)
A company's customer database is valued at $50,000. A breach would destroy/corrupt 40% of its value (Exposure Factor). Historical data shows this type of breach occurs about twice a year (Annualized Rate of Occurrence = 2). Calculate the Single Loss Expectancy (SLE) and the Annualized Loss Expectancy (ALE). Show all formulas used.

Q3. Brute-Force Attack Time Estimation (10 marks)
An 8-character password uses a 62-character set (a-z, A-Z, 0-9). An attacker's cracking rig tests 1 billion passwords per second. Calculate the size of the keyspace and the worst-case time required to exhaust it. Express your answer in hours.

Q4. Risk Prioritization Matrix (10 marks)
Given five threats rated on Likelihood (1-5) and Impact (1-5), compute the Risk Score (Likelihood x Impact) for each and rank them in order of patching/budget priority:
(a) Ransomware — L4, I5;
(b) Phishing — L5, I3;
(c) Insider data theft — L2, I5;
(d) DDoS — L3, I3;
(e) Unpatched server exploit — L4, I4.

Q5. Passive vs. Active Threat Classification (5 marks)
Classify each of the following as a passive or active threat, and state which CIA principle it primarily threatens:
(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.
(b) An attacker performing ARP spoofing to redirect traffic.
(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Q6. Threat Intelligence Lifecycle sequencing (10 marks)
A SOC analyst receives an executive request: "Are we at risk from the ransomware group currently targeting our industry?" Arrange the following into the correct order of the Threat Intelligence Lifecycle, and name each phase:

(i) Analysts correlate collected IOCs with internal logs.
(ii) A report is sent to the CISO.
(iii) The request itself is logged as a requirement.
(iv) OSINT and threat feeds are pulled for the group's known TTPs.
(v) The CISO's follow-up questions shape the next collection cycle.

ANSWERS

Q1. CIA Triad — Scenario Identification
Scenario: An attacker changes product prices in the database of an e-commerce site. The site remains online, so customers can still access it, but the data is no longer trustworthy.

- **Confidentiality:** This principle ensures that sensitive information is not disclosed to unauthorized parties. In this case, there is no evidence of customer data being leaked, so confidentiality is not violated.

- **Integrity:** This principle ensures that data remains accurate, consistent, and trustworthy. Since product prices were altered without authorization, the integrity of the database is compromised. Customers are seeing manipulated values, which undermines trust.
- **Availability:** This principle ensures that systems and data remain accessible when needed. The site stayed online, so availability was not affected.

Detailed Explanation: The incident is a clear violation of **integrity** because unauthorized modifications were made to critical business data. Even though the system was available and confidentiality wasn't breached, the accuracy of the information was destroyed. This highlights how attackers can cause damage without taking systems offline.
Answer: Integrity is violated.

🔹 **Q2. Risk Quantification — Annualized Loss Expectancy**

Given:

- Asset Value (AV) = $50,000
- Exposure Factor (EF) = 40% = 0.4
- Annualized Rate of Occurrence (ARO) = 2

Step 1: Single Loss Expectancy (SLE) Formula: $SLE = AV \times EFSLE = 50{,}000 \times 0.4 = 20{,}000$→ Each breach results in a $20,000 loss.
Step 2: Annualized Loss Expectancy (ALE) Formula: $ALE = SLE \times AROALE = 20{,}000 \times 2 = 40{,}000$→ Expected yearly loss is $40,000.
Detailed Explanation:

- **SLE** quantifies the financial impact of a single incident.
- **ALE** projects the total annual risk by multiplying the single incident cost by the frequency of occurrence. This helps organizations decide whether investing in security controls (e.g., firewalls, monitoring) is cost-effective compared to the expected losses.
  Answer: SLE = $20,000, ALE = $40,000.

🔹 **Q3. Brute-Force Attack Time Estimation**

Given:

- Password length = 8 characters
- Character set size = 62 (26 lowercase + 26 uppercase + 10 digits)
- Cracking speed = 1 billion passwords/sec = 10^9/sec

Step 1: Keyspace size Formula: Keyspace $= (\text{Character set size})^{\text{Password length}} 62^8 = 218{,}340{,}105{,}584{,}896 \approx$ **2.18 × 10^14 combinations**
Step 2: Worst-case cracking time Time = $\frac{\text{Keyspace}}{\text{Speed}} \frac{2.18 \times 10^{14}}{10^9} = 2.18 \times 10^5$seconds = 218,340 seconds ≈ **60.65 hours**
Detailed Explanation:

- Worst-case assumes attacker must try every possible combination.
- On average, success occurs in half the time (~30 hours).
- This demonstrates why short passwords are vulnerable: modern hardware can brute-force them in just a few days. Longer passwords or multi-factor authentication are essential.
  Answer: Keyspace = 2.18×10^{14}, Worst-case time ≈ **61 hours**.

🔹 **Q4. Risk Prioritization Matrix**

Formula: Risk Score = Likelihood × Impact
Calculations:

- (a) Ransomware → 4 × 5 = **20**
- (b) Phishing → 5 × 3 = **15**
- (c) Insider theft → 2 × 5 = **10**
- (d) DDoS → 3 × 3 = **9**
- (e) Unpatched exploit → 4 × 4 = **16**

Ranking (highest priority first):

1. Ransomware (20)
2. Unpatched exploit (16)
3. Phishing (15)
4. Insider theft (10)
5. DDoS (9)

Detailed Explanation: Risk scores help organizations allocate resources effectively.

- **Ransomware** is top priority because it combines high likelihood with catastrophic impact.
- **Unpatched exploits** are next because they are both likely and damaging.
- **Phishing** is frequent but less damaging per incident.
- **Insider theft** has high impact but low likelihood.
- **DDoS** is disruptive but less severe compared to data loss.
  Answer: Priority order: Ransomware → Unpatched exploit → Phishing → Insider theft → DDoS.

🔹 **Q5. Passive vs. Active Threat Classification**

- (a) **Sniffing unencrypted Wi-Fi traffic** → **Passive threat** (attacker only listens). Violates **Confidentiality**.
- (b) **ARP spoofing** → **Active threat** (attacker injects false ARP replies to redirect traffic). Violates **Integrity** (data routing altered) and can affect Availability.
- (c) **Long-term reconnaissance** → **Passive threat** (silent observation). Violates **Confidentiality**.

Detailed Explanation:

- **Passive threats** involve monitoring or eavesdropping without altering data. They primarily target confidentiality.
- **Active threats** involve direct interference, modification, or disruption, threatening integrity and availability.
  Answer: (a) Passive–Confidentiality, (b) Active–Integrity, (c) Passive–Confidentiality.

🔹 **Q6. Threat Intelligence Lifecycle**

Phases in correct order:

1. **Requirement** → (iii) Request logged (CISO asks about ransomware group).
2. **Collection** → (iv) Gather OSINT & threat feeds for TTPs.
3. **Processing/Analysis** → (i) Correlate IOCs with internal logs.
4. **Dissemination** → (ii) Report sent to CISO.
5. **Feedback** → (v) CISO's follow-up questions refine cycle.

Detailed Explanation: The Threat Intelligence Lifecycle ensures intelligence is **driven by organizational needs**.

- It begins with requirements (executive request).
- Then analysts collect relevant data (OSINT, feeds).
- Processing and analysis turn raw data into actionable intelligence.
- Dissemination delivers findings to decision-makers.